

Section 07

Industrial Security (Bachelor)



Section 07 – Risk Management

Risk Management

Lecture Notes

Department of Computer Science

2026-05-17

Industrial Security (Bachelor)

Section 07

Industrial Security (Bachelor)



Section 07 – Risk Management

Risk Management
Lecture Notes
Department of Computer Science

1 Risk Fundamentals

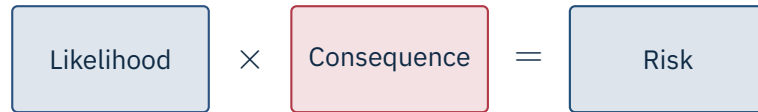
2 Methodologies

By the end of this section you will be able to

- Construct and interpret a qualitative risk matrix for an industrial site.
- Apply Cyber-HAZOP / Cyber-PHA techniques.
- Distinguish IT risk from safety risk.
- Recognise the Consequence-Driven Cyber-Informed Engineering (CCE) approach.

1

Risk Fundamentals



Consequence dimensions

Safety, environment, production loss, reputation, regulatory.
Likelihood depends on adversary capability *and* exploit difficulty.

2026-05-17

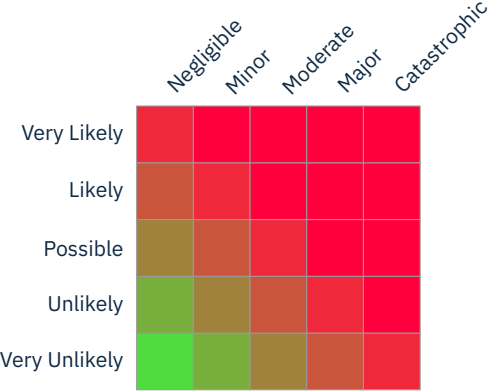
Industrial Security (Bachelor)
└ Risk Fundamentals

└ Risk in Industrial Contexts

Risk in Industrial Contexts 07

Consequence dimensions
Safety, environment, production loss, reputation, regulatory.
Likelihood depends on adversary capability and exploit difficulty.

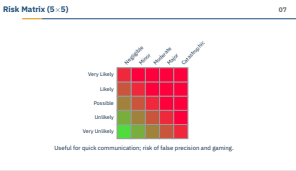
Open by underlining that OT risk is *non-linear*: once consequence reaches the safety or environmental tier, no amount of low likelihood makes the residual risk acceptable. The product form $L \times C$ is a teaching aid, not a physical law — regulators (Seveso III, IEC 61511) require you to drive safety risk down regardless of likelihood. Contrast with classic IT risk, where confidentiality breaches scale roughly linearly with exposure. Ask the room: what happens to this equation when C contains a fatality? (Answer: the multiplication collapses — the consequence axis dominates.) Transition: “so how do practitioners actually plot this?”



Useful for quick communication; risk of false precision and gaming.

2026-05-17 Industrial Security (Bachelor)
└ Risk Fundamentals

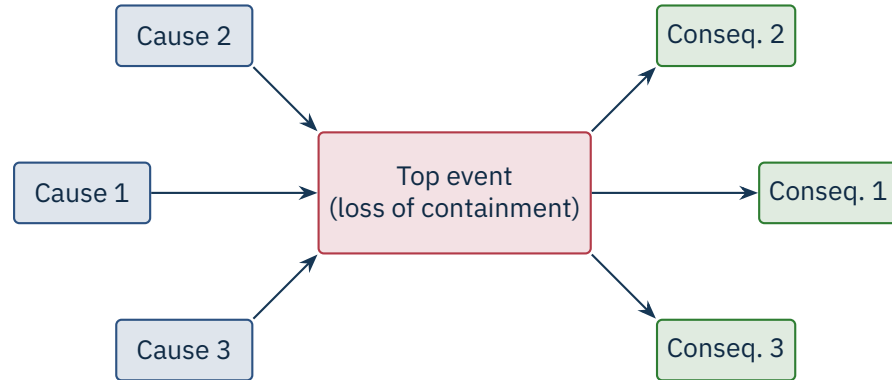
└ Risk Matrix (5×5)



Make the misconception explicit: “a risk matrix is objective” — no, the *colour bands are policy*. Two companies can use the same 5×5 grid and disagree on which cells are red because they have different appetites. NIST SP 800-30 R1 and ISO 31000:2018 both call out this calibration step. Common failure modes: cell-creep (analysts move scores left to escape red), category-stuffing (one “major” bucket that swallows everything from 1 h downtime to a fatality). Ask: “who in your organisation owns the colour scheme?” — usually nobody, which is the problem. Transition: “let’s look at methods that surface the underlying logic.”

2

Methodologies

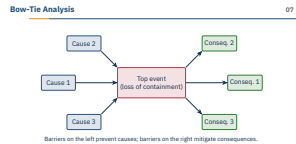


Barriers on the left prevent causes; barriers on the right mitigate consequences.

2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Bow-Tie Analysis



The bow-tie is the diagram process-safety engineers already understand — which makes it the right onboarding tool for security people walking into a HAZOP room. The knot in the middle is the *top event* (loss of containment, runaway reaction, loss of view). Left side: threat paths and the barriers that stop them. Right side: consequence paths and the mitigations that limit damage. Stress that a *cyber* cause sits on the left like any other — “attacker writes setpoint” is just another initiating event. Transition: “HAZOP gives us the verb list to walk these causes systematically.”

No

More

Less

Reverse

As well as

For each node, ask:
“What if an **attacker** caused the deviation *[guide word]* *[parameter]*?”

Examples: no flow → attacker closes inlet valve; high pressure → attacker disables relief actuator.

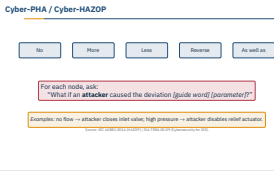
Source: IEC 61882:2016 (HAZOP) | ISA TR84.00.09 (Cybersecurity for SIS).

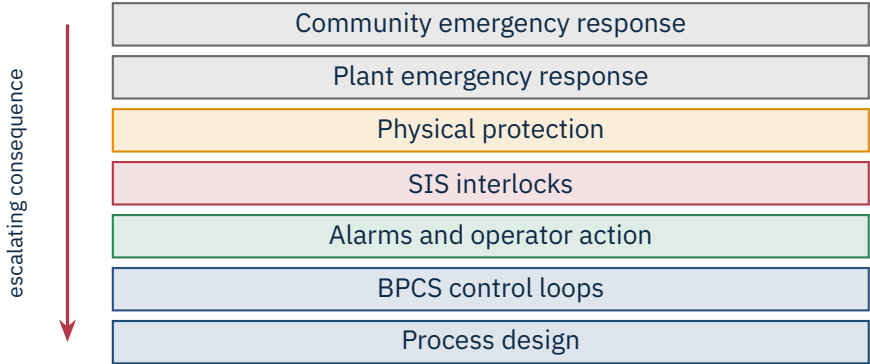
2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Cyber-PHA / Cyber-HAZOP

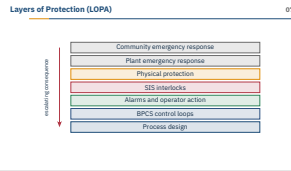
Cyber-HAZOP reuses the IEC 61882 guide words but adds an adversarial mind — not “what if the valve sticks open?” but “what if the attacker *holds* the valve open and spoofs the feedback?” ISA TR84.00.09:2017 codifies this as the bridge between functional safety (IEC 61511) and security (IEC 62443). The workshop must include a process engineer, an instrumentation engineer, and a security analyst — otherwise you get either fantasy attacks or hand-wavy consequences. The output is a list of cyber-induced deviations that feed straight into the LOPA worksheet. Ask: “which guide word is hardest for an attacker?” — usually “reverse”, because most attackers want a one-way bad state, not an oscillation.



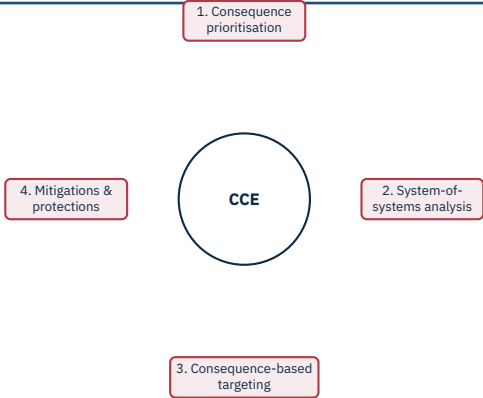


2026-05-17

- Industrial Security (Bachelor)
 - Methodologies
 - Layers of Protection (LOPA)



Walk top to bottom: each layer is a chance for the incident to be stopped before it escalates. The arrow on the left says “if all seven fail, the community is exposed.” This is the CCPS framing used in chemicals, refining, and LNG. Pre-empt the false-precision trap — LOPA gives a number but the number is only as good as the credit you assign each layer. Ask the room: which of these layers does cyber neutralise simultaneously? (Answer: anything that runs on the same DCS — BPCS, alarms, and an unhardened SIS can all collapse to a single common-cause cyber failure.) Transition: “next slide quantifies that intuition.”



INL methodology

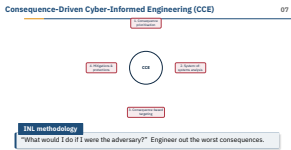
“What would I do if I were the adversary?” Engineer out the worst consequences.

Source: A. Bochman, S. Freeman, *Countering Cyber Sabotage*, INL/CRC Press, 2021.

2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Consequence-Driven Cyber-Informed Engineering (CCE)



This is the slide I want them to remember. Frame it as a single question: “*if you were the adversary, what would you do?*” — and then engineer that move *out*, not just monitor for it. Idaho National Laboratory developed CCE after concluding that perimeter security alone cannot stop a determined nation-state. Phase 1 prioritises the handful of consequences the business cannot survive (typically two or three, not twenty). Phase 3 is the uncomfortable one: you red-team your own crown jewels and find the kill chain that actually works. Tell them: “most companies do steps 1 and 4 and skip 2 and 3 — which is why they keep being surprised.”



Acceptance is legitimate

But it must be reviewed periodically – threats evolve.

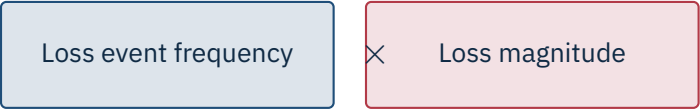
2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Risk Response Options

ISO 31000:2018 lists these four canonical responses. Stress that *avoidance* is underused in OT — if a function is risky and not load-bearing, remove it (do you really need that remote-engineering VPN to the Siemens S7?). Mitigation is the daily bread of security teams. Transfer is where insurance lives — and it does *not* reduce the underlying probability of harm. Acceptance must be a signed, time-bounded decision by someone with budget authority, not a default. Ask: “which of these does a CISO actually have authority over?” — usually only mitigation and acceptance; avoidance needs the COO.





= Annualised loss expectancy (ALE)

When FAIR earns its keep

When the board asks “how much does this risk actually cost us?” – and a heat-map is no longer enough.

Source: The Open Group, Risk Analysis (O-RA) Standard (FAIR), C20A:2021 | J. Jones & J. Freund, Measuring and Managing Information Risk, 2014.

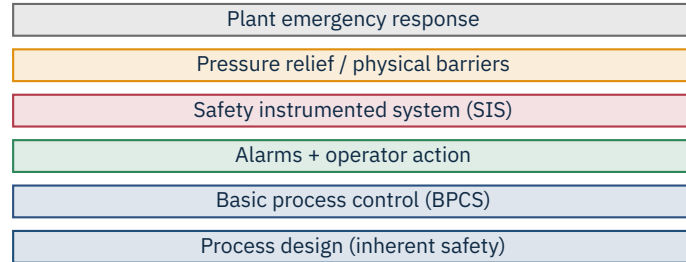
2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ FAIR – Quantitative Cyber Risk

FAIR (Factor Analysis of Information Risk) decomposes risk into measurable factors with confidence intervals — not point estimates. The Open Group’s O-RA standard formalises it. Where it earns its keep: capex justification, insurance renewal, board-level conversations where “high / medium / low” has stopped landing. Where it fails: when applied to safety-critical systems with sparse incident data — you end up with a confident-looking number sitting on top of guesses. NIST SP 800-30 R1 explicitly endorses semi-quantitative methods for exactly this reason. Ask: “would you bet your job on the ALE figure?” — if not, treat it as a directional signal, not truth.





Independence is the value

Each layer must be *independent of the next* – otherwise one common-cause failure removes them all.

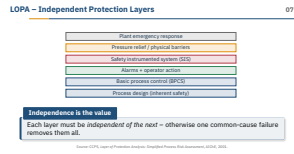
Source: CCPS, *Layer of Protection Analysis: Simplified Process Risk Assessment*, AIChE, 2001.

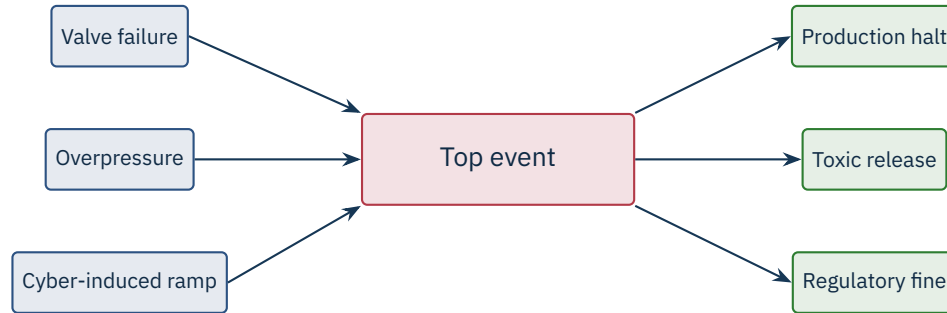
2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ LOPA – Independent Protection Layers

The point of LOPA is that probability and consequence are not the same axis. Walk through one row of the example: an attacker who can change a setpoint may, after several independent layers of protection, eventually cause a release. Each layer is a probability of failure on demand (PFD) – typically 10^{-1} to 10^{-2} – multiplied together. *Independence* is the single most violated assumption: if your SIS shares Windows engineering workstations with the BPCS, the layers are no longer independent and the math is wrong. IEC 61511 mandates this independence for safety-rated layers. Ask: which of these layers does cyber neutralise simultaneously? (Answer: anything that runs on the same DCS.)





Barriers on the left prevent causes; barriers on the right mitigate consequences.

2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Bow-Tie Example – Loss of Containment



Concrete example to make bow-tie click: pick the cyber-induced ramp on the bottom-left. Walk left-to-right: attacker writes a slow setpoint ramp, BPCS executes obediently, alarms suppressed because the rate is below threshold, SIS not tripped because the value stays under the trip point until too late — top event reached. Right side: toxic release, production halt, regulatory fine. Now ask the room to nominate *barriers*: rate-of-change alarm independent of BPCS, change-management on setpoints, signed downloads to the SIS. This is exactly how a Cyber-PHA workshop runs. Transition: “every barrier is either a control we have or a control we owe.”

	Qualitative	Quantitative
Speed	Hours	Days to weeks
Data needed	Workshop + expert judgement	Frequency & impact data
Output	Heat map / risk matrix	Loss curve in money
Use cases	Initial triage	Board / insurance / capex
Pitfalls	False precision	Garbage in ⇒ garbage out

	Qualitative	Quantitative
Speed	Hours	Days to weeks
Data needed	Workshop + expert judgement	Frequency & impact data
Output	Heat map / risk matrix	Loss curve in money
Use cases	Initial triage	Board / insurance / capex
Pitfalls	False precision	Garbage in ⇒ garbage out

These are not rivals — they answer different questions for different audiences. Qualitative is right for the first pass and for the workshop where you cannot yet defend numbers. Quantitative (FAIR, Monte Carlo, LOPA) is right when a decision turns on *how much*, not *how bad*. The trap on both sides is the same: pretending the output is more precise than the input. NIST SP 800-30 R1 explicitly recommends semi-quantitative as a pragmatic middle ground. Ask: “which would your CFO believe?” — usually the one with the dollar sign, even when the qualitative score is better calibrated. Transition: “so where does all of this land — in a register.”

- First-party: forensics, IR retainer, business interruption.
- Third-party: liability, regulator response.
- Typical exclusions: nation-state acts of war, unpatched known CVEs, missing MFA.
- Insurers now drive a minimum control baseline (MFA, EDR, backups).

Caution

Backstop, not a control Insurance is a backstop. Premiums rise sharply if your baseline is weak, and “act of war” exclusions are tested in court each year.

Source: Munich Re Cyber Insurance Risk Snapshot, 2024 | Merck v. Ace American (NotPetya war-exclusion ruling), New Jersey Appellate, 2022.

2026-05-17

Industrial Security (Bachelor) └ Methodologies

└ Cyber Insurance – What It Buys

Hit the misconception head-on: “buy insurance, problem solved” — no, *exclusions are everything*. The Merck v. Ace American case (NotPetya, settled after the 2022 New Jersey ruling) is the canonical example: insurer invoked the “hostile or warlike action” exclusion against a state-attributed wiper. Merck eventually won on appeal, but only because the policy language was old; modern policies have rewritten war exclusions specifically to cover state-attributed cyber. Also stress: insurers now *require* a control baseline (MFA, EDR, immutable backups) — they are effectively the new compliance authority. Ask: “does your risk register cite policy exclusions?” — if not, transfer is fictional.

Cyber Insurance – What It Buys07

- First-party: forensics, IR retainer, business interruption.
- Third-party: liability, regulator response.
- Typical exclusions: nation-state acts of war, unpatched known CVEs, missing MFA.
- Insurers now drive a minimum control baseline (MFA, EDR, backups).

Caution
Backstop, not a control Insurance is a backstop. Premiums rise sharply if your baseline is weak, and “act of war” exclusions are tested in court each year.

Source: Munich Re Cyber Insurance Risk Snapshot, 2024 | Merck v. Ace American (NotPetya war-exclusion ruling), New Jersey Appellate, 2022.

- **Ransomware on Historian** – Likely / Major / **H**: immutable backups, EDR.
- **SIS reprogrammed by attacker** – Unlikely / Catastrophic / **H**: key-switch + signed downloads.
- **Vendor account abuse** – Possible / Major / **H**: MFA, brokered remote access, session recording.
- **USB-borne malware** – Likely / Moderate / **M**: USB allow-listing, kiosk scanner.
- **PLC firmware CVE** – Possible / Major / **M**: vendor patch in maintenance window; virtual patch on IPS meanwhile.

2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ Risk Register Example

A risk register is a living document, not a tickbox — every row carries an owner, a control set, a residual rating, and a review date. Read one entry aloud: *SIS reprogrammed by attacker* — unlikely, but catastrophic, hence still high; mitigations are key-switch and signed downloads, both per IEC 62443-3-3. Stress that this register is the artefact regulators (NIS2, NIST 800-82 R3) actually ask to see during an inspection. Without it you cannot demonstrate that risks were considered and consciously treated. Ask the class: “what would you add to this list for a water utility?” — expect chlorine dosing, SCADA poll-rate, and remote-pumping-station physical security.

Risk Register Example

07

- **Ransomware on Historian** – Likely / Major / **H**: immutable backups, EDR.
- **SIS reprogrammed by attacker** – Unlikely / Catastrophic / **H**: key-switch + signed downloads.
- **Vendor account abuse** – Possible / Major / **H**: MFA, brokered remote access, session recording.
- **USB-borne malware** – Likely / Moderate / **M**: USB allow-listing, kiosk scanner.
- **PLC firmware CVE** – Possible / Major / **M**: vendor patch in maintenance window; virtual patch on IPS meanwhile.

★ Key Takeaway: What to remember from this section

- Industrial risk has dimensions IT does not: safety, environment, regulatory.
- Cyber-HAZOP integrates security into the language of process safety teams.
- LOPA reminds us that several independent layers must fail for a disaster.
- CCE asks: how would the adversary win? – and re-engineers to remove the winning move.

Close the loop: this section is the bridge between the technical sections that came before and the governance sections that follow. The CCE question — “if you were the adversary, what would you do?” — is the one I want you to leave with. Reinforce that no single methodology is sufficient: heat maps for speed, LOPA for independence math, FAIR for money, Cyber-PHA for safety language, CCE for the worst-case re-engineering. Each maps to a standard: ISO 31000, IEC 61511, O-RA/FAIR, ISA TR84.00.09, INL CCE. Transition to the next section: “now that we know what to defend and how badly, the next section asks *who decides* — governance and standards.”

★ Key Takeaway: What to remember from this section

- Industrial risk has dimensions IT does not: safety, environment, regulatory.
- Cyber-HAZOP integrates security into the language of process safety teams.
- LOPA reminds us that several independent layers must fail for a disaster.
- CCE asks: how would the adversary win? – and re-engineers to remove the winning move.

- The Open Group. *Risk Analysis (O-RA) Standard*, C20A, 2021 (FAIR).
- Jones, J., Freund, J. *Measuring and Managing Information Risk: A FAIR Approach*, Butterworth-Heinemann, 2014.
- Center for Chemical Process Safety (CCPS). *Layer of Protection Analysis: Simplified Process Risk Assessment*, AIChE, 2001.
- IEC 61882:2016. *Hazard and operability studies (HAZOP studies) – Application guide*.
- ISA-TR84.00.09:2017. *Cybersecurity related to the Functional Safety Lifecycle*.
- Bochman, A., Freeman, S. *Countering Cyber Sabotage: Introducing Consequence-Driven, Cyber-Informed Engineering (CCE)*, INL/CRC Press, 2021.
- IEC 62443-3-2:2020. *Security risk assessment for system design*.
- NIST SP 800-30 Rev. 1. *Guide for Conducting Risk Assessments*, 2012.
- ISO 31000:2018. *Risk management – Guidelines*.

2026-05-17

Industrial Security (Bachelor)
└ Methodologies

└ References – Section 07

- The Open Group. *Risk Analysis (O-RA) Standard*, C20A, 2021 (FAIR).
- Jones, J., Freund, J. *Measuring and Managing Information Risk: A FAIR Approach*, Butterworth-Heinemann, 2014.
- Center for Chemical Process Safety (CCPS). *Layer of Protection Analysis: Simplified Process Risk Assessment*, AIChE, 2001.
- IEC 61882:2016. *Hazard and operability studies (HAZOP studies) – Application guide*.
- ISA-TR84.00.09:2017. *Cybersecurity related to the Functional Safety Lifecycle*.
- Bochman, A., Freeman, S. *Countering Cyber Sabotage: Introducing Consequence-Driven, Cyber-Informed Engineering (CCE)*, INL/CRC Press, 2021.
- IEC 62443-3-2:2020. *Security risk assessment for system design*.
- NIST SP 800-30 Rev. 1. *Guide for Conducting Risk Assessments*, 2012.
- ISO 31000:2018. *Risk management – Guidelines*.

End of Section 07

Risk Management

Questions and discussion

